Information Security Policy

Document ID	SEC-001
Department	IT and Information Security
Document type	Policy
Owner	Chief Information Security Officer
Version	1.3
Status	APPROVED
Effective / last reviewed	2025-10-25
Audience	All employees and contractors
Related documents	SEC-002, SEC-005, SEC-006, SEC-010

Summary. Top-level information security policy of Northstar Systems. It sets security principles, governance roles, mandatory baseline controls, awareness training, exception handling, and how the detailed standards on access, passwords, devices, data and vulnerabilities fit beneath it.

SYNTHETIC DOCUMENT - Northstar Systems is a fictional company. This document exists for development, testing and demonstration only and is not real legal, employment, security or compliance advice.

1. Purpose and Scope

This policy is the top-level statement of how Northstar Systems Private Limited protects the confidentiality, integrity and availability of its information, its customers' information and the systems that process them. It sets the principles and the mandatory baseline. Detailed requirements live in the supporting documents listed in section 12, and where a supporting document is more specific, the more specific document applies provided it does not weaken this policy.

The policy applies to all employees, contractors, consultants, interns and third parties who access Northstar information or systems, at the Whitefield (Bengaluru) headquarters, the Powai (Mumbai) office, remote locations across India, and any cloud environment operated by Northstar, including the primary Mumbai region and the secondary Hyderabad disaster recovery region. It covers information in every form: electronic, paper and spoken.

This policy is approved and owned by the Chief Information Security Officer (CISO), reviewed at least once every 12 months, and communicated to every joiner during onboarding. Legal and regulatory references in this document are illustrative and must be verified by Legal before external use.

2. Definitions

- **Information asset**: any data, system, device, application, document or service that has value to Northstar.
- **Security Desk**: the 24x7 reporting point for security matters, reachable at security@northstar-systems.example or hotline extension 5555.
- **Security Incident Response Team (SIRT)**: the cross-functional team led by the Incident Response Lead, a delegate of the CISO.
- **NorthID**: the single sign-on and identity platform that enforces multi-factor authentication (MFA).

- **NorthVault**: the approved password and secrets manager.
- **NorthGuard**: the endpoint management (MDM) platform that reports device encryption and patch status.
- **NorthWatch**: the monitoring, alerting, log search and SIEM platform.
- **NorthDesk**: the internal service desk used for access requests, change tickets and exception requests.
- **Control owner**: the named person accountable for operating a specific control.
- **Risk acceptance**: a documented, time-limited decision by an authorised person to tolerate a known gap.
- **Restricted data**: the highest data classification level, defined in SEC-005.

3. Security Principles

All security decisions at Northstar follow these principles.

1 **Least privilege.** People and systems receive only the access needed for their current role and nothing more (see SEC-002).
2 **Defence in depth.** No single control is relied on. Identity, device, network, application and data controls overlap.
3 **Secure by default.** New systems, accounts and configurations start in the most restrictive state, with default-deny network rules.
4 **Need to know.** Confidential and Restricted information is shared only with people who need it for a documented purpose.
5 **Accountability.** Every account belongs to one person or one documented service. Shared accounts are prohibited.
6 **Report early.** Suspected incidents are reported immediately; reporting in good faith is never penalised.
7 **Proportionality.** Control strength follows the sensitivity of the asset and the likelihood and impact of harm, not convenience.
8 **Continuous improvement.** Audit findings, incidents and near misses feed back into standards.

4. Governance and Roles

4.1 Responsibilities

Role	Responsibility
CEO and executive team	Sponsor the security programme, fund it, and accept risks above the CISO's authority
CISO	Owns this policy and the security programme, chairs the quarterly security review, approves standards
Incident Response Lead	CISO delegate who leads SIRT and approves time-limited exceptions and risk acceptances
Security Engineering Manager	Owns technical standards for authentication and vulnerability management, runs scanning and tooling
Head of IT Operations	Operates endpoints, identity infrastructure and patching
Privacy Officer	Reports to the General Counsel and decides on personal-data breach notifications
Department heads	Ensure their teams follow security policy and nominate control owners
Reporting managers	Approve access, enforce training completion, and escalate concerns

Role	Responsibility
All personnel	Follow policy, protect credentials and devices, complete training, report incidents

4.2 Security governance forums

The CISO chairs a security review every quarter, attended by the CTO, VP Engineering, Head of IT Operations, the Privacy Officer and a Finance representative. The review covers incident trends, vulnerability status against service levels, audit findings, open exceptions and the programme budget. Minutes and action items are tracked in NorthDesk with an owner and a due date.

Each engineering team has a Security Champion who performs security-sensitive code review (authentication, cryptography and personal-data handling changes) and acts as the first point of contact for security questions from that team.

5. Mandatory Baseline Controls

The following controls apply to everyone and every system in scope. The detailed standard is named for each.

5.1 Identity and access

- Every employee uses NorthID with MFA for all corporate systems. There are no exceptions for convenience.
- Access is role-based, requested through the NorthDesk Access Request form, and approved by the reporting manager and the system owner. Privileged and production access follows the stricter approvals in SEC-002.
- Joiner access is ready by day 1, mover changes are completed within 2 business days, and leaver accounts are disabled by 18:30 IST on the last working day.
- Passwords follow SEC-003: minimum 14 characters, stored only in NorthVault, no routine forced rotation, and no reuse across systems.

5.2 Devices

- Company work is done only on company laptops. Personal laptops must not be used.
- Full-disk encryption is mandatory and verified through NorthGuard. Screens lock after 5 minutes.
- A lost or stolen device must be reported to the Security Desk within 1 hour of discovery. Details are in SEC-004.

5.3 Data

- All information is classified as Public, Internal, Confidential or Restricted. Handling and retention follow SEC-005.
- Restricted data must be encrypted at rest and in transit, shared only through approved tools, and never placed in personal email or in external AI tools.
- No secrets are stored in source code. Secrets live in NorthVault or a KMS-backed secret store.

5.4 Network and systems

- Employees reach internal applications through the NorthTunnel VPN with MFA.
- Production administration is performed only through the NorthGate bastion, with session recording.

- There is no direct inbound internet access to production except through a load balancer with a web application firewall. Guest Wi-Fi is isolated from the corporate network. Firewall rules are reviewed every quarter.

5.5 Encryption

- AES-256 is used for data at rest. TLS 1.2 is the minimum for data in transit, and TLS 1.3 is preferred.
- Keys are held in the cloud KMS, signing keys in an HSM, and the KMS master key is rotated every 12 months. TLS certificates have a 90-day lifetime with automatic renewal.

5.6 Vulnerability management

- Vulnerabilities are remediated within the service levels in SEC-007: Critical 72 hours, High 14 days, Medium 30 days, Low 90 days, and mitigation within 24 hours for any actively exploited vulnerability.
- Vulnerability scans run weekly, and an external firm performs a penetration test each year.

5.7 Logging and monitoring

- Security audit logs are kept for 24 months in tamper-evident storage, with time synchronised through NTP. Privileged actions are always logged.
- Security Operations reviews logs weekly in NorthWatch. Employee monitoring is permitted and is described in SEC-015.

5.8 Business continuity and third parties

- A Business Impact Analysis is performed every year. The Crisis Management Team is led by the COO. If the Bengaluru headquarters becomes unavailable, all Bengaluru staff work remotely within 4 hours and critical teams operate from the Mumbai office. The Maximum Tolerable Downtime for customer platform operations is 4 hours, and a BCP exercise is held each year.
- Critical and High tier vendors must complete a security questionnaire and provide an independent assurance report (for example SOC 2 Type II or an ISO 27001 certificate, illustrative) before a purchase order is issued. Assessment takes 10 business days from a complete questionnaire. Critical vendors are reassessed annually and High vendors every 2 years.

5.9 Common questions

- Can I use my personal laptop for a quick task? No. Only company laptops may be used for company work. A BYOD phone may be used for email and NorthID only after NorthGuard mobile enrolment.
- Do I need to change my password every few months? No. Passwords are changed only when compromise is suspected, but they must be at least 14 characters and unique.
- Who do I call if I clicked a suspicious link? Call the Security Desk on extension 5555 at once, even if you are unsure. Early reports are never penalised.
- May I paste customer logs into an external AI tool to debug a problem? No. Customer production data is Restricted and must never be placed in external AI tools.

6. Security Awareness and Training

New joiners must complete mandatory security training in NorthLearn within 14 days of joining. All personnel complete an annual refresher. Phishing simulations run every quarter. An employee who

fails 3 simulations within 12 months must complete mandatory retraining and has a conversation with their manager. Failing a simulation is a learning event, not a disciplinary one, but repeated disregard of security policy can lead to action under the HR disciplinary process (see HR-005).

Reporting managers receive a monthly completion report. A joiner who has not completed training by day 14 has access to non-essential systems suspended until it is done, after a reminder at day 10.

Example: A new Support Engineer joins on 3 March. Her training is due by 17 March. On 13 March (day 10) NorthLearn sends a reminder to her and her manager. If she has not finished by 17 March, her NorthAssist elevated rights are suspended until she completes the course.

7. Acceptable Use and Personal Responsibility

Personal use of company devices is limited and must not break any policy. Unauthorised software must not be installed. Only AI tools on the Approved AI Tools list may be used for work, and no Confidential or Restricted data may be entered into external AI tools. Company email is for business use only.

Every person must:

- Lock their screen when leaving a device, even briefly.
- Never share a password, MFA code or hardware key with anyone, including IT staff. The IT Service Desk (extension 4000) never asks for a password.
- Escort visitors and challenge unbadged strangers in office areas.
- Keep paper containing Confidential or Restricted information in locked storage and shred it when no longer needed.
- Use the Report Phish button for any suspicious email and not forward it to colleagues.

8. Incident Reporting

Anyone who suspects a security incident must report it to the Security Desk immediately, by calling extension 5555 or writing to security@northstar-systems.example. Phishing emails are reported with the Report Phish button. Do not attempt to investigate on your own, do not delete evidence and do not discuss the incident on public channels.

The Security Desk triages every report and assigns a severity of Critical, High, Medium or Low. Critical aligns with a production SEV1. SIRT, led by the Incident Response Lead, works through the phases of detect, triage, contain, eradicate, recover and review. Forensic evidence is preserved for 12 months. Customer notification of a confirmed breach affecting their data happens within 72 hours of confirmation, which is a contractual commitment (illustrative). Regulatory notifications, such as CERT-In style 6-hour reporting of specified incident types, are illustrative and must be verified by Legal. The Privacy Officer decides on personal-data breach notifications.

Example: An employee notices that a laptop bag was stolen from a cab on the way from the Whitefield office. She calls extension 5555 within the hour, and the Security Desk confirms the loss. NorthGuard then sends a remote wipe within 4 hours of confirmation, and the employee also informs the IT Service Desk so a replacement can be raised.

9. Risk Management

The CISO maintains a security risk register, reviewed at each quarterly security review. Each risk has an owner, a rating based on likelihood and impact, and a treatment decision: mitigate, transfer, avoid or accept. Business Impact Analysis is repeated annually and feeds the continuity plan led by the COO.

New high-risk processing of personal data, new critical vendors and major architectural changes require a security review before approval. A Data Protection Impact Assessment is required for new high-risk personal-data processing (illustrative; verify with Legal). Third parties are tiered Critical, High, Moderate or Low and assessed accordingly, with a Data Processing Agreement required before any personal data is shared.

10. Exceptions and Risk Acceptance

If a requirement cannot be met, the requester must raise an exception in NorthDesk that states the control affected, the business reason, the compensating controls, and the end date.

Situation	Who may approve	Maximum duration
Technical exception to a standard (for example a legacy system that cannot meet a control)	CISO delegate (Incident Response Lead) risk acceptance	90 days, renewable only with fresh justification
USB mass storage on a company laptop	CISO delegate	30 days
Exception to this policy itself	CISO	90 days, reported at the quarterly review
Risk with potential material customer or financial impact	CISO and CEO jointly	Set case by case, reviewed every quarter

Exceptions expire automatically. An expired exception that is not renewed is treated as a policy violation, and the control owner is asked to restore compliance. No exception may permit a shared account, the removal of MFA from production, or the storage of Restricted data in personal email or external AI tools.

Example: The finance team relies on a legacy reporting tool that cannot support MFA through NorthID. The Head of IT Operations raises a NorthDesk exception for 90 days, documents compensating controls (access only through NorthTunnel, access limited to 4 named users, extra log review in NorthWatch) and a migration plan. The Incident Response Lead approves it with an expiry date. If the migration slips, a new request with fresh justification is needed.

11. Compliance, Audit and Consequences

Compliance is monitored through NorthGuard reports, NorthWatch dashboards, quarterly access reviews, internal audit each year and an external audit each year (ISO 27001-style, illustrative). High audit findings must be remediated within 60 days, and the control owner reports progress at each quarterly review.

Violations are assessed on intent and impact. Accidental, promptly reported violations lead to coaching. Negligent or repeated violations are handled under the HR disciplinary ladder: verbal warning, written warning, final written warning, termination. Deliberate misuse, such as copying Restricted data to a personal account, may result in immediate action up to termination and, where applicable, legal action. Contractors who violate policy may have their engagement ended.

12. Related Documents

This policy sits at the top of the security document set. Access rules are in SEC-002 and password and authentication rules are in SEC-003. Device requirements are in SEC-004, data classification and retention in SEC-005, and vulnerability and patching in SEC-007. See also SEC-006 and SEC-010 for related security procedures, and SEC-015 for monitoring and acceptable-use detail.

13. Revision History

Version	Date	Change
1.1	2024-11-04	Added AI tools restriction and phishing simulation rules
1.2	2025-04-14	Aligned exception durations and training deadlines
1.3	2025-10-25	Updated governance forum, incident reporting and audit sections